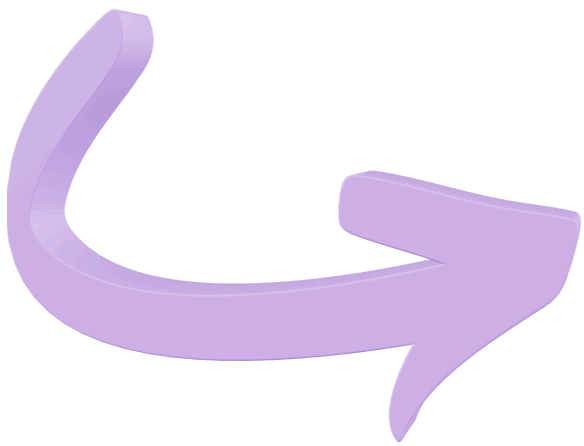
GENERAL SECURITY CONCEPTS

SECURITY CONTROLS

- measures used to protects assets- i.e data, physical property, or computer systems.
- ensure confidentiality, integrity, availability, and non-repudiation (ensures action cant be denied.
- help prevent security incidents, reduce their impact and limit damage.

CONTROL CATEGORIES

- technical controls also known as logical controls. implemented to manage and reduce risks using computer systems such as hardware, software, or firmware. e.g. firewalls, AV Software, access control, least privilege, IDS & IPS, encryption, Radius servers, RAID arrays etc,



- Radius servers fall under access control.
- RAID arrays fall under data protection and availability

Radius Server

- stands for Remote Authentication Dial-In User Service.
- Controls network access against unauthorised access
- Verifies users' identities before granting network access.

Imagine you arrive at work and connect to the company's Wi-Fi.

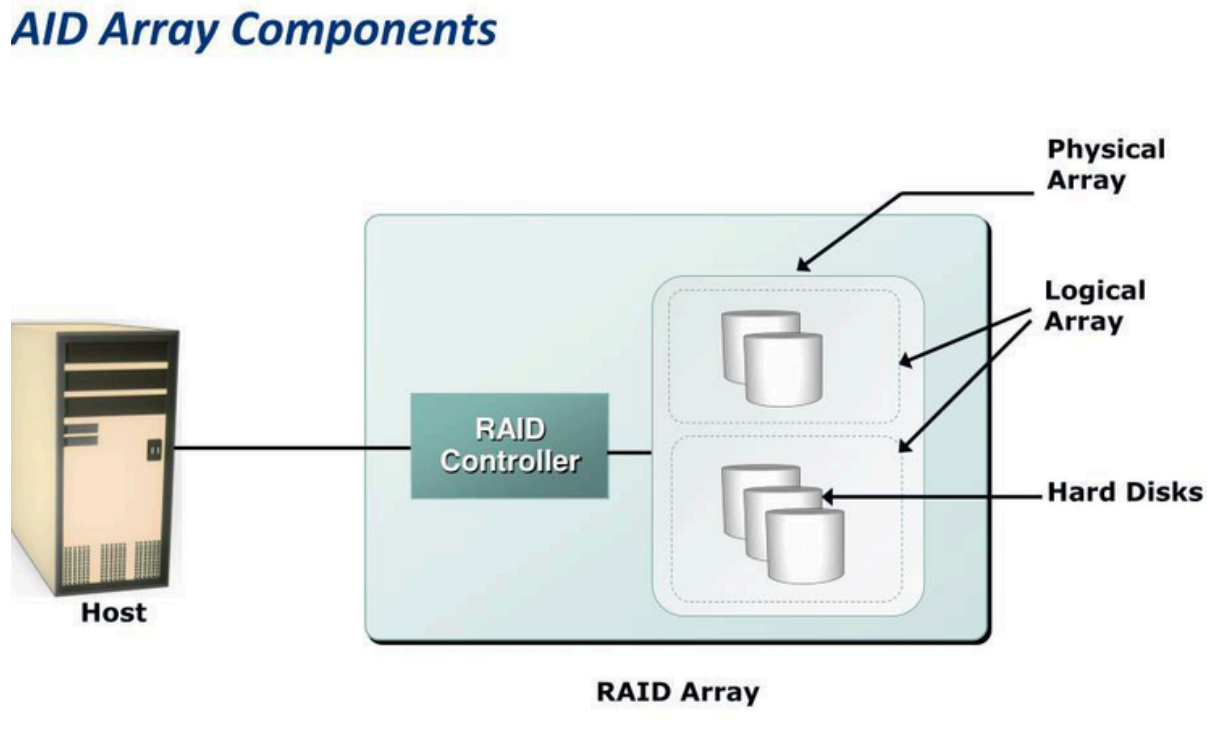
1. You enter your username and password.
2. The network asks the RADIUS server to check your login details.
3. The server verifies whether you are authorised.
4. If your details are valid, you are allowed to connect. If not, access is denied.

RAID Arrays

- RAID stands for Redundant Array of Independent Disks.
- A RAID array combines multiple hard drives or solid-state drives to improve data reliability, performance, or both, depending on how it is configured.

Why is it a technical control?

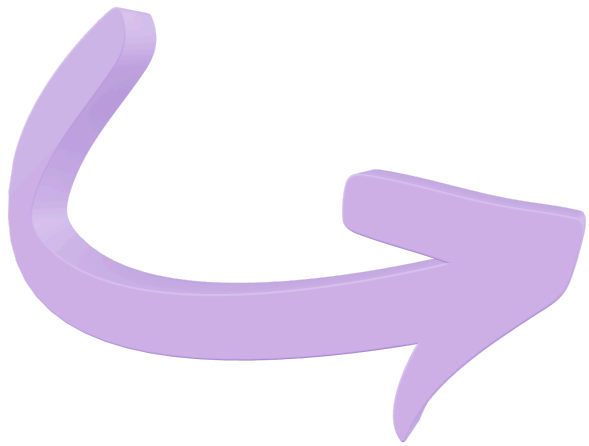
It can improve data availability and protect against data loss caused by certain hardware failures.



- operational controls are procedures and measures that are designed to protect data on a day-to-day basis. Are mainly governed by internal processes and human actions. e.g. user access reviews, log monitoring, and vulnerability management, awareness and training, configuration management, media protection, physical and environmental protection

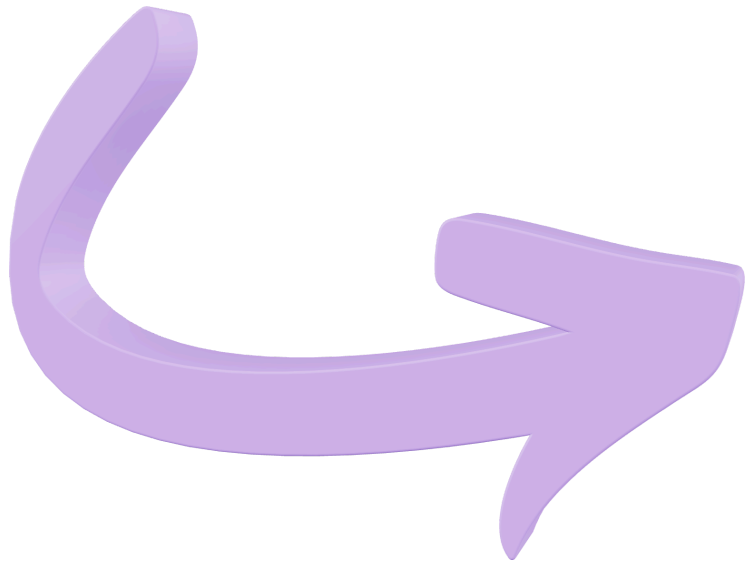
- managerial controls a.k.a administrative controls are all about the mechanics of risk management process such as identifying risks and choosing the right control. often linked to security policies and standard operating procedures. e.g. risk assesments, vulnerability assessments, security awareness training, formal change management.

- physical controls limit physical access using the built environment to enhance safety and prevent crime. e.g. include fences, perimeter lighting, locks, fire suppression systems, and burglar alarms.



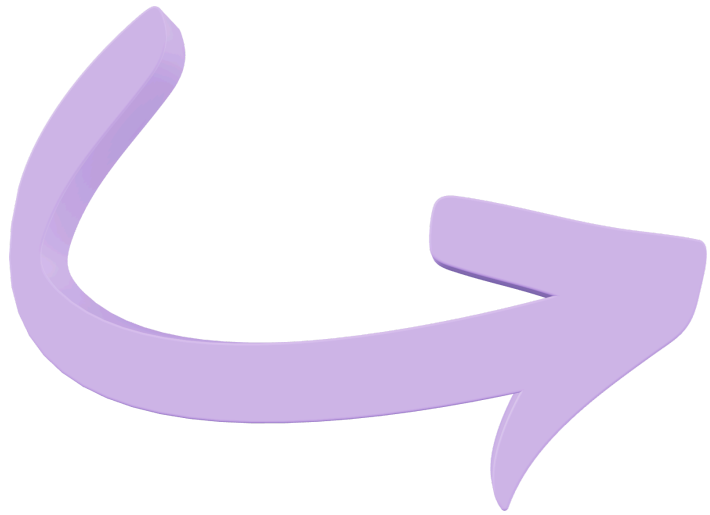
  - barricades/bollards: prevent access and channel people through defined points. allows people, prevent unauthorized vehicles, secure infrastructure e.g. concrete bollards, moats.

- access control vestibules: security measure with two interlocking doors that only allow one person to pass at a time. first door opens after access is granted, second door opens only when first door is shut. prevents unauthorized access and tailgating.



- fencing: protect exterior of a building. can be transparent or opaque. secure against climbing, robust.

- video surveillance: can replace physical guards. records movement and access for later review. longer response times. needs enough staff monitor feeds.



- security guards: physical protection at critical checkpoints. verify identification, allow/disallow access, log entry events. can respond to security breaches.

- lighting: enhances perception of safety and security at night. deterrent to intrusion, aids surveillance.

- sensors:

1. infrared: detects changes in heat patterns. common in motion detectors.
2. pressure: detects change in force. e.g floor & window sensors.
3. microwave: detects movement across large areas.
4. ultrasonic: emits soundwaves and measures return time. detect motion, collision detection etc.

CONTROL TYPES

- preventative controls: intend to stop a security issue before it occurs. e.g. Firewalls and encryption, hardening, training, security guards, change management, account disablement policy, intrusion prevention system (IPS)
- deterrent controls: discourage potential attackers by making the effort seem less appealing or more challenging. e.g. Vicious guard dogs and barbed wire fences, signs & warnings.

Compare to prevention

- Deterrent encourages people to decide not to take an undesirable action
- Prevention stops them from taking an undesirable action
- Security guard can be both

- detective controls: Monitor and alert organizations to malicious activities as they occur or shortly thereafter e.g. logs, Intrusion detection systems (IDS), Security Information & Event Management systems, motion detection.
- corrective controls: remediate security issues that have already occurred. Mitigate any potential damage and restore our systems to their normal state. e.g. backup systems, patch management systems, fault tolerance

- compensating controls: alternative measures that are implemented when primary security controls are not feasible or effective. e.g. network access control(NAC), data loss prevention(DLP).

- directive controls: enforces rules of behaviour, policies and procedures e.g. procedures, policy guidelines standard, security training programs, acceptable use policies(AUP), incident response plan (IRP).

CIA TRIAD

- confidentiality: prevents disclosure of information to unauthorized individuals. e.g. encryption, access control, 2FA, firewalls.

1. Encryption — Scramble the information

Converts readable information into coded information so unauthorized people cannot understand it without the required key.

2. Access controls — Decide who can enter

Allow only authorised users to access particular information.

3. Data masking — Hide sensitive details

Hides parts of sensitive information while allowing the data to remain useful for authorised purposes.

Example: A card number appears as **** **** **** 1234 instead of showing the full number.

- integrity: data is stored and transported as intended, without unauthorized modifications. e.g. hashing, digital signature, certificate checksums.

1. Hashing — Create a digital fingerprint

A mathematical process converts data into a fixed-length value called a hash.

2. Digital signatures — Verify who signed and whether data changed

Help confirm the identity of the signer and detect changes made to signed data.

3. Checksums — Check whether data was damaged

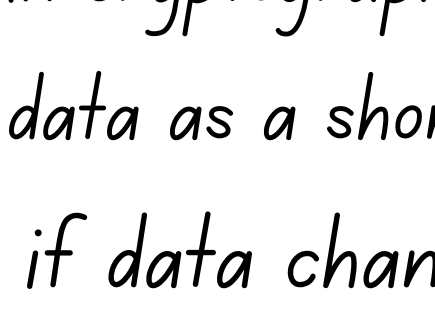
A value is calculated from data and checked again later to help detect accidental changes or transmission errors.

- availability: information is accessible to unauthorized users when needed. e.g redundancy(build servers that will always be available), fault tolerance (system continues to run even when failure occurs), patching(stability, close security holes), failover, RAID, backups, load balancing.

NON-REPUDIATION

- ensures that a person cant deny performing an action, such as creating, modifying, or sending a resource
- acts as proof of origin and integrity. e.g signing a contract leaves your signature as proof.

- in cryptography: ensure integrity by using a hash (represent data as a short string of text) i.e. message digest or fingerprint.
- if data changes, the fingerprint changes too. proof of tampering.
- add authentication to verify source of the message
- sign with private key (e.g. digital signature)
- anyone can check the integrity with corresponding public key



- To confirm the authenticity of digital transactions
- To ensure the integrity of critical communications
- To provide accountability in digital processes

AUTHENTICATION, AUTHORIZATION & ACCOUNTING

- *authentication*: Security measure that ensures individuals or entities are who they claim to be during a communication or transaction

authenticating people

- *identification*: creating an account or ID representing the user, devuce or process e.g. username
- *authentication*: proving the identity of a subject attempting to access a resource e.g. passwords

authenticating systems

- put a digitally signed certificate on the device.
- an organization has its own certificate authority(CA).
- the organiztion can create a certificate for a device and digitally sign the certificate with the organizations CA.
- the certificate can now be included on a device as an authentication factor,
- the CAs digital signature is used to validate the certificate.

- authorization: Determines which resources a verified user can access and what actions they can perform.
- An authorization model is a set of rules that determines who can access which resources and what they can do with them.
- scalable, easy to understand and supports any number of users and resources
- e.g. RBAC (Role-Based Access Control) Permissions are assigned according to a person's job role, ABAC (Attribute-Based Access Control) Access depends on attributes such as job title, location, device security or time, MAC (Mandatory Access Control) Access is determined by centrally enforced security classifications and clearance levels, DAC (Discretionary Access Control) The resource owner decides who can access the resource.

- accounting: security measure that ensures all user activities during a communication or transaction are properly tracked and recorded.
- Records and tracks a user's activity, resource usage and access sessions.

- AAA: Authentication, Authorization, Accounting.
- Authorization models: RBAC, ABAC, MAC, DAC.
- AAA protocols: RADIUS, TACACS+.
- Authentication methods: SFA, 2FA, MFA, risk-based authentication.

GAP ANALYSIS

- the process of comparing an organisation's current security controls with the requirements of a security framework or standard to identify what is missing, inadequate or incorrectly configured.

How does gap analysis work?

- Identify the requirements: Choose the framework or standard the organization wants to meet.
- Review the existing controls: Check what security measures are already in place.
- Identify the gap: Compare the required controls with the actual controls.
- Recommend and prioritise improvements: Document the missing controls, assess the risks and plan corrective action according to available time and resources.

When is gap analysis performed?

- When adopting a new security framework.
- When preparing to meet new compliance requirements.
- Periodically, to check whether security controls remain adequate.

What does gap analysis produce?

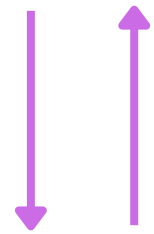
- overall score
- list of missing/poorly configured controls
- remediation recommendations

ZERO TRUST

- requires all devices, users & processes to be authenticated and authorized before accessing a network resources.
- assumes no inherent trust inside or outside a networks perimeter.
- split into functional planes
- applies to physical, virtual and cloud environments.

Control plane — Makes the decisions

Determines who should have access, which policies apply and how network traffic should be handled.



Decisions and instructions guide traffic handling

Data plane — Handles the traffic

Processes and forwards packets, enforces access decisions, and may encrypt or translate network traffic.

Key concepts within the control plane

1. adaptive identity

- considers source & requested resource
- evaluates mulitple risk indicators such as relationship to the organization, type of connection, IP address, physical location.

2. threat scope reduction

- decreases number of possible entry points

3. policy-driven access control

- combines adaptive identity with predefined set of rules

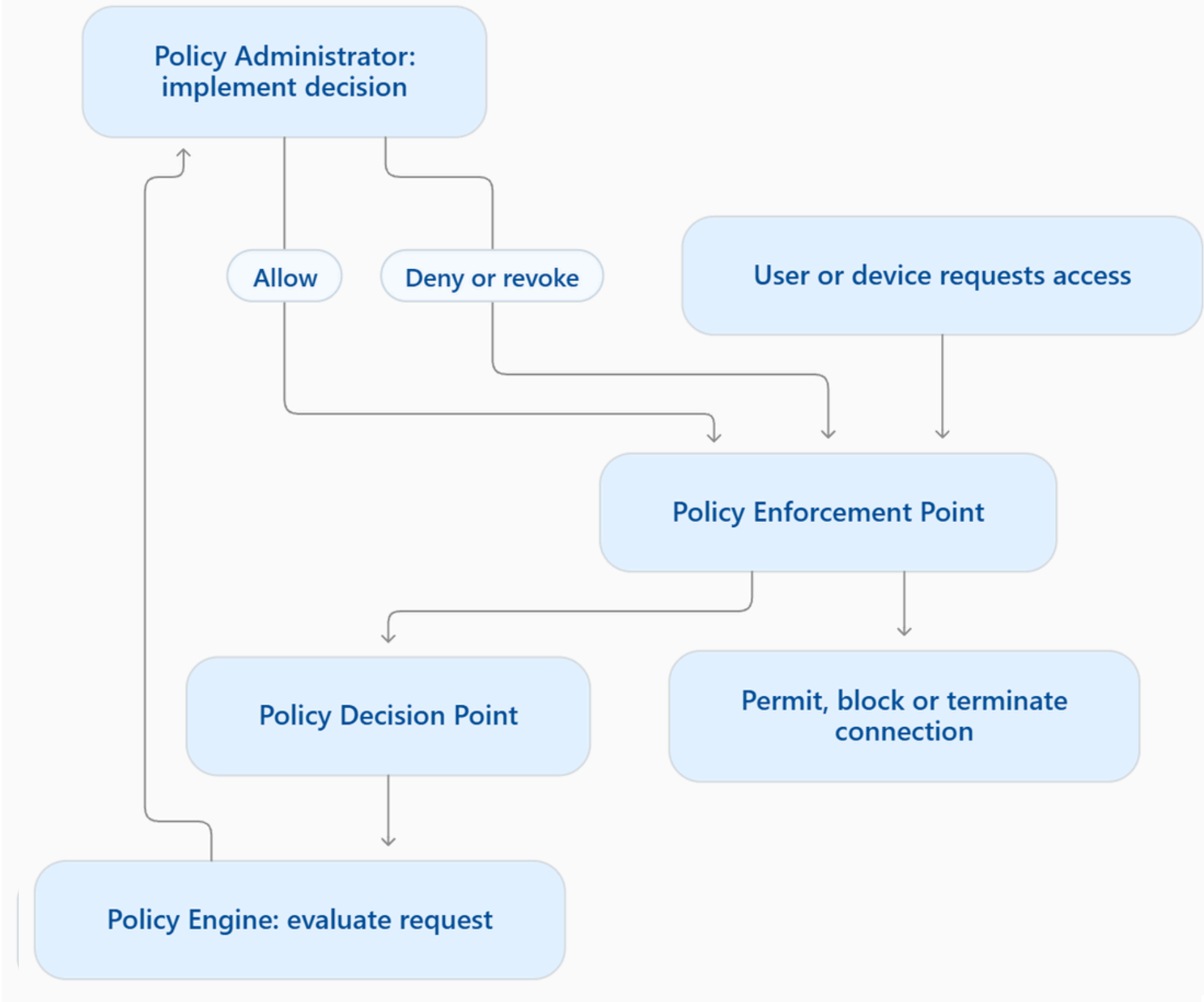
components of contol plane

- policy engine: evaluates each access decision based on policy and ither information sources. grants, denies or revokes access.
- policy administrator: Carries out the Policy Engine's decision. grants access tokens or credentials. tells PEP to allow or disallow access.

components of data plane

- policy enforcement point: applies to subjects and systems. The gatekeeper/security checkpoint. It enables, monitors and terminates connections according to the access decision.

#policy decision point: process for making an authentication decision.



- PE = Evaluates the request.
- PA = Implements the decision.
- PDP = PE + PA.
- PEP = Enforces the decision.

Security zones group systems or network resources according to security requirements.

Implicit trust means assuming something is safe without independently verifying the relevant access request.

Example: Automatically allowing every device on the internal network to access a database.

This is contrary to the Zero Trust principle. Being inside the network is not, by itself, sufficient reason to grant access.

DECEPTION & DISRUPTION STRATEGIES

1. Honeypot — A fake system

A decoy computer, server or application designed to attract attackers and study their tactics & tools

2. Honeynet — A network of fake systems

A collection of interconnected honeypots that simulates a larger network. Defenders observe how the attacker moves between them.

3. Honeyfile — A fake file

A decoy document that appears to contain valuable or confidential information. Detect attempts to access or steal data

4. Honeytoken — Fake information used as a trap

A decoy piece of data, such as a fake username, password, API key or database record. Its use can trigger an alert.

CHANGE MANAGEMENT

- change management is a systematic approach to managing changes in an organization, ensuring they do not negatively impact security or performance.
- types of change: software deployment, system updates, software patching, hardware replacements, upgrades, network modification, system configurations, new product implementations, new software integrations, support, environment changes.
- The change management process involves documentation, risk assessment, approval, and review.

Three important factors affecting change management

1.Change management approval process

- begins with submitting a request for change
- reviewed by a designated change manager or committee.
- followed by formal approval involving stakeholders
- ocumentation and communication throughout the proces

2. Ownership

- The owner is the person or team accountable for coordinating the change.
- ensuring it is implemented as planned, managing risks and communicating progress.

3. Stakeholders

- individuals or groups who may be affected by the change or have an interest in its outcome.
- Examples include system users, IT staff, management and customers.

Change Management Concepts

- Impact analysis: Identify and assess how a proposed change could affect users, business processes, systems, security, and operations.
- Test results: Test the change in a controlled environment before deploying it to the live system. ensure changes work as intended, identify potential issues.
- Backout plans: contingency plans for reversing changes. minimize downtime and reduce risk of data loss
- maintenace window: A predefined schedule for implementing a change, preferably during periods of low activity to reduce disruption.
- standard operating procedure: detailed instructions for routine operations or changes.

Technical Implications of Change Management

1. Allow lists and denial lists

- Allow list: A list of approved software, hardware, users, or change types. reduce time and effort for trusted changes, ensure alignment with organization. e.g. routine or low-risk changes
- Denial list: A list of explicitly blocked software, hardware, users, or change types. block unauthorized, high-risk changes, clearly identify unauthorized changes. e.g. software with known security issues, high-impact changes, or unauthorized individuals.

2. Restricted activities

- certain activities are deliberately restricted or tightly controlled because they can introduce instability, security risks, or compliance violations if not managed properly.
- Downtime and restarts: directly affect business operations. minimize disruptions by scheduling during maintenance windows or off-peak times. ensure that stakeholders are aware of service outages to prepare accordingly. e,g. Service restart: Stops and starts a background service or system process or Application restart: Closes and relaunches an application, creating a fresh running instance.

3. legacy applications

- unique challenges in managing changes due to outdated technology and lack of support.
- It requires specialized solutions and expensive testing.

4. Dependencies

- Dependencies occur when one application, service, or system relies on another to function correctly.
- Dependencies can extend to the time needed for changes and backup plans.

5. Documentation

- Change documentation records what was changed, why it was changed, who approved it, and whether it was successful.
- Documentation should include: Change description and reason, Risk and impact assessment., Approval details and responsible personnel., Implementation steps and test results, Backup and rollback procedures, Updated system configurations and network diagrams, New or changed dependencies, Recovery procedures and employee training requirements.

6. version control

- track and control changes to documents and dats
- assess how changes impact existing policies, procedures, and diagrams.
- label new versions, archive old ones.

CRYPTOGRAPHIC SOLUTIONS

- cryptography: art of making information secure by encoding it

terminology

- plaintext: unecrypted message
- ciphertext: encrypted message
- algorithm: process used to encrypt and decrypt a message
- cryptoanalysis: art of cracking cryptographic solutions

PUBLIC KEY INFRASTRUCTURE

- Public Key Infrastructure (PKI) is the complete system used to manage cryptographic keys, digital certificates, policies, and trust between users, devices, and organizations.
- It helps verify that a public key belongs to the person, organization, or device it claims to represent.

Main functions of PKI

- Key pair management: Supports the generation and management of public and private keys.
- Certificate management: Issues, validates, renews, and revokes digital certificates.
- Policies and procedures: Establishes rules for how keys and certificates must be used and protected.

- Trust management: Allows systems to verify that a public key is associated with the claimed identity.
- Security: Helps protect communications, verify digital signatures, and support secure authentication.

PUBLIC KEY CRYPTOGRAPHY

- Uses public (encryption) and private (decryption) keys for cryptographic operations.
- digital signature: sign with private key, verify with public key

KEY ESCROW

- involves the secure storage of a copy of a cryptographic key with a trusted third party, called an escrow agent, so that the key can be recovered under authorized conditions.
- making multiple copies increases the risk of compromise and makes detection difficult.
- M-of-N control requires a minimum of M authorised people out of N total designated people to approve or perform a sensitive operation. it prevents a single individual from performing key recovery operations

ENCRYPTION AND DATA PROTECTION

The three states of data

- Data at rest: data that is stored and not currently being transmitted. e.g. Hard drives, USB devices, backup tapes, cloud storage. Protection: Full disk, volume, file, or database encryption.
- Data in transit: data moving between systems over a network. e.g. Online banking, email transmission, file transfers. Protection: TLS, IPsec, and WPA3 for supported Wi-Fi communications.
- Data in use: data currently being processed by a computer, usually in memory. e.g. An open document, data being processed by an application, database records loaded into RAM. Protection: Access controls, process isolation, and specialised confidential-computing techniques.

Types of encryption

1. Bulk encryption

- encrypts large amounts of data (MB or GB)
- symmetric ciphers: efficient for large data e.g. AES

2. Full disk encryption (FDE)

- encrypts entire storage device including metadata and free space. guards against physical theft by requiring user credentials to unlock the decryption key.

3. Self-encrypting drives (SEDs)

- have built-in encryption, not exposed to the OS. e.g. HDD, SSD, USB flash drives.

4. partition encryption

- allows selective encryption for different partitions e.g. boot, system, data.

5. volume encryption

- encrypts a storage resource with a single file system e.g. microsft bitlocker, apples filevault.

6. file encryption

- encrypts individual files or folders e.g. microsoft EFS.

7. database encryption

- protects data stored in structured databases by encrypting data at various levels such as database-level, record-level, and cell/column level.

type	what it protects	key point
Database-level encryption	Broadly protects database storage, often through transparent data encryption (TDE).	Usually protects data files at rest, not necessarily data after it is decrypted for processing.
Record-level encryption	Protects individual records.	Different records can have separate protection requirements.
Cell/column-level encryption	Protects selected fields or columns.	Useful for highly sensitive values, such as identity or financial information.

Transport encryption

- protects data as it travels across networks
- TLS (Transport Layer Security): Protects communications such as HTTPS connections between a browser and a website.
- IPsec: Protects IP network traffic, commonly for VPNs.
- WPA2/WPA3: Protects wireless network communications.

.

key exchange

- enable secure sharing of symmetric session keys

What protects integrity and authenticity?

- HMAC: Uses a secret key and a cryptographic hash function to help verify data integrity and authenticity.
- Authenticated encryption: Provides confidentiality and integrity, and may provide authenticity, when used correctly. AES-GCM is a common example.

symmetric encryption

- Symmetric encryption uses the same shared secret key to encrypt and decrypt data.

Sender

Original message: plaintext

Shared secret key + encryption algorithm

Encrypts the message

Ciphertext

Encrypted message sent to the receiver

Same shared secret key + decryption algorithm

Decrypts the message

Receiver

Recovers the original plaintext

- symmetric algorithms: agreement on cipher/key, emcryption, transmission, decryption, fast, suitable for large data. secure method needed for key exchange.
- For integrity and authenticity, systems can combine encryption with a message authentication code (MAC), or use authenticated encryption such as AES-GCM.
- Substitution cipher: Replaces characters or groups of characters with different characters. e.g. ROT13 changes HELLO to URYYB.
- Transposition cipher: Keeps the original characters but changes their positions. e.g. TEAM could be rearranged to META.
- Modern algorithms such as AES combine multiple rounds of transformations, including substitution and permutation, to provide strong cryptographic protection.

- AES, DES, 3DES
- The AES cipher allows the use of three key strengths: 128 bits, 192 bits, and 256 bits.

Key length

- A cryptographic key is a value used by an encryption algorithm to encrypt or decrypt data.
- Key length: The number of bits in a cryptographic key.
- Key space: The total number of possible keys an attacker might have to try.
- The longer the key, the more possible combinations an attacker may need to test in a brute-force attack.
- e.g. AES-128 Key space: (2^{128}) possible keys
- larger keys provide stronger security but also consider performance and the algorithm's design.

- Key sizes from different cryptographic algorithms are not directly equivalent.
- For example, RSA and elliptic-curve cryptography (ECC) achieve comparable security with different key lengths. An RSA key of 1,024 bits is not a modern secure recommendation; it is too weak for current security needs. RSA-2048 is a common minimum baseline, while ECC can provide comparable security with much shorter keys.
- ROT13 is a simple substitution cipher that shifts each letter by 13 positions.

asymmetric encryption

- uses two different but related keys (public and private key) for encryption and decryption.
- Public key distribution does not compromise security.

How asymmetric encryption works

Imagine Alice wants to send Bob a confidential message.

Step 1: Bob generates a key pair

Bob keeps his private key secret and shares his public key with Alice.

Step 2: Alice encrypts the message

Alice uses Bob's public key to encrypt her message.

Step 3: Alice sends the ciphertext

The encrypted message travels over the network.

Step 4: Bob decrypts the message

Bob uses his private key to decrypt the original message.

- Intercepting the public key and ciphertext should not enable an attacker to recover the plaintext

Asymmetric algorithms

- RSA: 2,048-bit private key
- ECC: 256-bit private key for high security
- DSA — Digital Signature Algorithm: Designed for creating and verifying digital signatures, rather than encrypting messages. It helps verify authenticity and integrity.

key exchange

- the process of establishing or securely sharing cryptographic key material between two parties so they can communicate securely.
- Asymmetric encryption is generally slower than symmetric encryption, so encrypting an entire large message with public-key cryptography is inefficient.
- Instead, systems commonly use hybrid encryption:
- Asymmetric cryptography helps protect or establish a session key.
- Symmetric cryptography encrypts and decrypts the actual message.
- A session key is a temporary symmetric key used to protect data during a communication session.

How a digital envelope works

Imagine Alice wants to send Bob a large, confidential file.

Step 1: public key acquisition

Alice obtains Bob's public key

Step 2: session key encryption

Alice encrypts message with symmetric key.

Step 3: session key encryption with public key

Alice encrypts the session key with Bobs public key

Step 4:digital envelope

Alice sends encrypted session key and ciphertext

Step 5: session key decryption

Bob decrypts session key with private key

Step 6: message decryption

Bob uses the recovered session key to decrypt the ciphertext.

#in-band key exchange: is on the network. protect key with additional encryption such as TLS

#out-of-band key exchange: don't send symmetric key over the net

TOOLS

- dedicated servers or applications generate and store keys e.g TPM, HSM, KSM, Secure Enclaves.
  Trusted Platform Module (TPM)
- Protects keys and supports measured boot, platform-state checks and attestation.
- Common TPM functions include: Secure key storage, Random number generation, Remote attestation (Helps a remote verifier assess boot measurements and system state.), Binding (Protects data so it can be recovered using the appropriate TPM-associated key.), Sealing (Protects data so that access or unsealing depends on specified TPM or platform-state conditions.)

Hardware Security Module (HSM)

- A Hardware Security Module is a specialised hardware device designed to generate, protect, store and use cryptographic keys.
- Typical uses include: Protecting certificate-authority signing keys, Generating and protecting encryption keys, Performing digital signatures and cryptographic operations, Providing controlled access to sensitive key material.

Key Management System (KMS)

- A Key Management System (KMS) manages cryptographic keys throughout their lifecycle

Key lifecycle

- Generation: Create asymmetric key pair or symmetric secret key
- Storage : prevents unauthorized access and loss/damage
- Revocation: Prevent further use when a key is compromised or no longer trusted.
- Expiration and renewal: shelf-life enhances security. renewal with same or new key pair.

decentalised km: Keys are managed separately by individual applications, devices or users.

centralised km: Policies and lifecycle operations are managed through a central service. e.g KMS

secure enclave

- protects decrypted data in system memory from unauthorized access.
- security prevents access by untrusted processes, even with root or system privileges.
- implemented by Trusted Execution Environment (TEE) like Intel Software Guard Extensions

OBFUSCATION

- holds data to make it difficult to find

steganography

- the technique of concealing secret information within an ordinary-looking file or communication medium to prevent the existence of the message from being detected.
- conceals the very existence of the communication
- The image, document or other medium used to conceal the information is commonly referred to as the cover medium
- The hidden message may be encrypted before embedding, thereby combining cryptography and steganography to provide an additional layer of security

data masking

- used to conceal sensitive information by replacing some or all of its characters with substitute characters, such as Xs, asterisks, or blank spaces.
- a credit card number may be displayed as **** **** **** 1234
- used to prevent unauthorized users from viewing sensitive information in applications, databases, reports, and other information systems.
- Techniques associated with data masking include character substitution, shuffling, encrypting, masking out etc.

tokenization

- replaces sensitive information with a non-sensitive substitute known as a token.
- tokens and original values are stored separately in a token server or vault
- used as a substitution for encryption

HASHING

- represent data as a short string of text
- one-way function (impossible to recover plaintext) and collision-resistant (unlikely for different inputs to produce the same output).

#integrity verification: 1. password comparison: hashes compared to verify psswords. 2. file integrity: hashes compared to verify file integrity

cryptographic hash algorithms

- the Secure Hash Algorithm (SHA) family and the Message Digest 5 (MD5) algorithm
- SHA-1 and MD5 have known collision weaknesses and should not be used where collision resistance is required for security
- SHA-256, SHA-512, and suitable SHA-3 variants remain widely used for cryptographic integrity applications.

Hash-Based Message Authentication Code (HMAC)

- a security mechanism that combines a cryptographic hash function, such as SHA-256 or SHA-3, with a shared secret key to verify message integrity and authenticity.
- Both the sender and recipient must know the secret key to generate or verify the HMAC
- Unlike digital signatures, HMAC does not provide non-repudiation because both parties share the same secret key.

DIGITAL SIGNATURES

- combines hashing and public-key cryptography to provide message integrity, authentication and support for non-repudiation.

How it works:

1. Hashing: Alice generates a message digest using a secure hash algorithm, such as SHA-256 or SHA3-512.
2. Signing: Alice uses her private key to create a digital signature over the digest.
3. Sending: Alice sends the message together with the digital signature to Bob.
4. Verification: Bob uses Alice's public key to verify the signature and independently hashes the received message.
5. Comparison: If verification succeeds, Bob gains evidence that the message has not been altered and that the signature was generated using the corresponding private key.

DIGITAL CERTIFICATES

- electronic document that links an entity's identity to its public key.
- It is issued and digitally signed by a trusted Certificate Authority (CA), which helps other parties verify that the public key belongs to the claimed entity.
- follow the X.509 standard and are used to secure websites, email, devices and digitally signed software.

Certificate revocation

- Certificate Revocation List (CRL): A published list of revoked certificates. Revoked certificate or Suspended certificate.
- Online Certificate Status Protocol (OCSP): Allows a client to query a service for a certificate's revocation status.

Types of certificates and certificate authorities

Type	Explanation
Self-signed certificate	Signed using its own private key rather than a trusted CA. Common in testing and private environments, but requires a separate method of establishing trust.
Third-party CA	Root certificate authority issues certificates to intermediate certificate authorities, which in turn issue certificates to end entities.
Root CA	establishes trust between users and certificate authorities by using root certificates, which are self-signed by the certificate authority and used to sign other certificates.
Single-CA model	The root CA directly issues certificates to users and computers, often used on private networks, vulnerable because if compromised, the entire PKI collapses

KEY STRETCHING

- increases key length through multiple iterations.
- uses algorithms such as PBKDF2, which repeatedly applies hashing and other operations to increase the time required for attackers to test password guesses.

SALTING

- prevents precomputed hash attacks by adding random value (salt) to passwords.
- Salting helps defend against precomputed attacks, such as rainbow-table attacks, and makes large-scale password cracking less efficient.

BLOCKCHAIN

- distributed digital ledger that records transactions across multiple computers.
- Information is stored in blocks linked together using cryptographic hashes.
- Each block typically contains transaction data, a timestamp, and the hash of the previous block.
- This linking makes unauthorized changes detectable and helps protect the integrity of the records.
- decentralized: Public blockchains can operate without a central transaction-processing authority.
- Applications: Cryptocurrency, Property records, supply chain management, Asset tracking.

SUBJECT ALTERNATIVE NAME (SAN)

- an extension in a digital certificate that specifies the identities the certificate covers, such as fully qualified domain names (FQDNs), subdomains and IP addresses.
- Browsers use SAN entries to verify that a website's identity matches its certificate.
- A single certificate can include multiple domain names, and SAN entries may include wildcard domains where supported.
- Example: A single certificate can cover example.com, example.org and example.net.

WILDCARDS

- A digital certificate that secures multiple subdomains under the same domain using a wildcard (*).
- It simplifies certificate management and can reduce costs, but if its private key is compromised, all covered subdomains may be affected.
- Example: *.example.com can cover www.example.com, mail.example.com and shop.example.com